Rapporto sull'incidente di sicurezza

Sezione 1: individuare il protocollo di rete coinvolto nell'incidente

Il protocollo coinvolto è HTTP (Hypertext Transfer Protocol), che lavora a livello applicativo. Le pagine di yummyrecipesforme.com viaggiano su HTTP, e il log di tcpdump mostra il browser che lo usa per comunicare con il sito. Lo stesso protocollo ha portato il file dannoso sui computer dei visitatori.

Sezione 2: documentare l'incidente

Diversi clienti hanno scritto all'helpdesk dicendo che il sito chiedeva di scaricare ed eseguire un file per ottenere ricette gratis. Dopodiché i loro computer sono diventati molto lenti. Nello stesso periodo il proprietario del sito non riusciva più ad accedere al proprio account admin.

Per indagare ho usato una sandbox, così la rete aziendale non correva rischi. Ho avviato tcpdump, ho aperto il sito, ho accettato il download e ho eseguito il file. Il browser mi ha poi mandato su un sito diverso, greatrecipesforme.com.

Il log di tcpdump racconta la stessa storia. Prima il browser chiede l'indirizzo IP di yummyrecipesforme.com e si collega con HTTP. Dopo l'esecuzione del file il traffico cambia: il browser chiede un nuovo indirizzo IP, quello di greatrecipesforme.com, e la connessione viene reindirizzata lì.

Un analista senior ha letto il codice sorgente del sito e del file scaricato. L'attaccante aveva aggiunto al sito un codice che proponeva un falso aggiornamento del browser, ed era quello il file dannoso. Dato che il proprietario era bloccato fuori dall'account admin, pensiamo che l'attaccante sia entrato con un attacco a forza bruta, abbia cambiato la password dell'admin e poi abbia modificato il sito.

Sezione 3: raccomandare uno o più rimedi contro gli attacchi a forza bruta

Per prima cosa impedirei di riutilizzare le vecchie password, e soprattutto quella predefinita. L'attaccante è entrato perché una password debole o predefinita funzionava ancora, quindi una nuova password deve sempre essere diversa dalle precedenti.

In secondo luogo limiterei i tentativi di accesso falliti e bloccherei l'account per un po' dopo qualche errore. Un attacco a forza bruta richiede migliaia di tentativi, quindi così diventa molto lento.

Terzo, aggiungerei l'autenticazione a due fattori (2FA). Anche se qualcuno indovina la password, gli servirebbe anche il codice monouso inviato al telefono o all'email del proprietario, quindi la sola password non basta più. Chiederei inoltre di cambiare la password a intervalli regolari.